

SOC 2 READINESS CONTROL MATRIX (SECURITY CRITERIA)	
Policy Owner:	Security Operations & Governance
Author:	Morolake Bolarinwa
Version:	1.0 (Final)
Effective Date:	September 2026

1. EXECUTIVE SUMMARY

As organizations scale cloud operations, sustaining compliance with the SOC 2 Trust Services Criteria (TSC) requires mapping technical implementations directly to audit frameworks. This project demonstrates a continuous compliance readiness assessment, mapping existing hybrid-cloud technical controls (Microsoft Entra ID, Microsoft Sentinel, and DLP policies) to the SOC 2 Common Criteria (Security).

The objective is to establish defensible, audit-ready evidence artifacts that bridge the gap between engineering operations and regulatory requirements.

2. SCOPE & FRAMEWORK ALIGNMENT

This matrix focuses specifically on the Security Trust Services Category, detailing how logical access, system monitoring, and risk mitigation are operationalized.

- Framework: AICPA SOC 2 (Type I / Type II Readiness)
- Environments In Scope: Microsoft Azure, Entra ID, Microsoft 365
- Primary Tooling: Microsoft Sentinel (SIEM), Entra ID Conditional Access, Microsoft Purview (DLP)

3. SOC 2 CONTROL MAPPING MATRIX

SOC 2 Criteria	Description	Technical Implementation (Control Activity)	Evidence Artifact / Logging	Status
CC6.1	Logical Access Control	Enforced Microsoft Entra ID Conditional Access requiring MFA for all administrative access and risky sign-ins.	Entra ID Sign-in Logs; MFA Configuration Policy	Implemented
CC6.2	User Registration & Deprovisioning	Implemented Role-Based Access Control (RBAC) and Privileged Identity	PIM Activation Audit History	Implemented

SOC 2 Criteria	Description	Technical Implementation (Control Activity)	Evidence Artifact / Logging	Status
		Management (PIM) for Just-In-Time (JIT) access to sensitive cloud resources.		
CC6.6	External Threat Protection	Deployed Microsoft Sentinel with custom KQL alert rules to detect anomalous login behaviors (e.g., impossible travel, brute force attempts).	Sentinel Incident Logs; Alert Configuration Rules	Implemented
CC6.8	Unauthorized Software Prevention	Baseline server configurations and endpoint protection policies deployed via Intune.	Intune Compliance Reports	Implemented
CC7.1	Vulnerability Management	Scheduled automated vulnerability scans on all cloud-hosted virtual machines using integrated cloud defender tools.	Vulnerability Scan Export (PDF/CSV)	Implemented
CC7.2	Security Event Monitoring	Centralized ingestion of Azure AD, Office 365, and firewall logs into Microsoft Sentinel for continuous monitoring and alerting.	SIEM Data Connector Status Dashboard	Implemented

4. STRATEGIC IMPACT & AUDIT READINESS

By translating technical safeguards into this formal compliance matrix, the organization achieves:

- **Accelerated Audit Cycles:** External auditors are provided with direct traceability between SOC 2 criteria and the technical evidence logs.
- **Continuous Monitoring:** Relying on automated SIEM alerts ensures that control effectiveness is monitored continuously, moving beyond point-in-time compliance.
- **Scope Reduction:** Clear demarcation of tools and evidence simplifies the evidence collection process for future SOC 2 Type II assessment periods.